

- **Expediente N.º: EXP202315109**

## RESOLUCIÓN DE TERMINACIÓN DEL PROCEDIMIENTO POR RECONOCIMIENTO DE RESPONSABILIDAD Y PAGO VOLUNTARIO

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

### ANTECEDENTES

PRIMERO: Con fecha 19 de noviembre de 2024, la Directora de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a **DISEÑOS HERMANAS ORTIZ CAÑÓN, S.L.** (en adelante, **HO**), mediante el acuerdo que se transcribe:

<<

**Expediente N.º: EXP202315109**

### ACUERDO DE INICIO DE PROCEDIMIENTO SANCIONADOR

De las actuaciones practicadas por la Agencia Española de Protección de Datos y en base a los siguientes

### HECHOS

PRIMERO: Con fecha 28 de agosto de 2023 se interpuso reclamación ante la Agencia Española de Protección de Datos por una posible infracción imputable a **DISEÑOS HERMANAS ORTIZ CAÑÓN, S.L.** con NIF **B39843487** (en adelante, **HO**).

El reclamante denuncia la existencia de una brecha de seguridad que afectó a **HO** y que supuso la exposición de los datos personales de miles de clientes, él entre ellos. Junto al escrito, el reclamante aporta enlace de una dirección de Internet donde figuran los datos filtrados.

Por parte de esta AEPD se procedió a la descarga y diligencia del fichero con los datos filtrados desde la url aportada por el reclamante.

SEGUNDO: De conformidad con el artículo 65.4 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante LOPDGDD), con fecha 27/10/2023 se dio traslado de dicha reclamación a **HO**, para que procediese a su análisis e informase a esta Agencia en el plazo de un mes, de las acciones llevadas a cabo para adecuarse a los requisitos previstos en la normativa de protección de datos.

La parte reclamada dio respuesta a la actuación de traslado y solicitud de información en fecha 24/11/2023, si bien de la información facilitada se infiere una posible vulneración de la normativa de protección de datos.

TERCERO: Con fecha 28 de noviembre de 2023, de conformidad con el artículo 65 de la LOPDGDD, se admitió a trámite la reclamación.

CUARTO: La Subdirección General de Inspección de Datos procedió a la realización de actuaciones previas de investigación para el esclarecimiento de los hechos en cuestión, en virtud de las funciones asignadas a las autoridades de control en el artículo 57.1 y de los poderes otorgados en el artículo 58.1 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), y de conformidad con lo establecido en el Título VIII, de la LOPDGDD.

Como consecuencia de las actuaciones realizadas, se ha tenido conocimiento de los siguientes extremos:

.-1-. Respecto a las evidencias aportadas y la cronología de los hechos denunciados.

La parte reclamante facilita el enlace de la publicación de la brecha en un foro desde el cual se puede acceder al link para descargar los datos.

La publicación en el foro **\*\*\*FORO.1**, con fecha 24 de junio de 2023, que refiere a una publicación en **\*\*\*PÁGINA WEB** con fecha 28 de noviembre de 2022, indica que en enero de 2022 la tienda Online de ropa **\*\*\*TIENDA.1** sufrió una brecha de datos personales que afectó a (...)clientes.

Una vez descargado el fichero [Datos\_\*\*\*FORO.1], se analizan los datos contenidos en el Excel del archivo descargado. Los datos contenidos en el Excel incluyen:

- Nombre y apellidos.
- Dirección postal y electrónica
- Datos de usuario y contraseña de su cuenta (cifrado)
- Datos de facturación: Nombre, apellidos, dirección postal y teléfono

Se comprueba que en el fichero Excel hay un total de (...) entradas, de las cuales dos filas contienen la información de la parte reclamante, en concreto las filas: 8.497 y 17.571.

También se confirma que las últimas fechas de usuarios registrados corresponden al 16 de enero de 2022, por lo que se podría deducir esta fecha como la fecha de la brecha de datos personales.

Tanto la captura de la publicación como el fichero descargado se encuentran incluidos en el expediente en SIGRID, como Documentos Anexos a la entrada de la parte reclamante.

Por lo tanto, se concluyen los siguientes hechos cronológicos:

. - Con fecha enero de 2022 (probablemente el día 16), se filtran los datos de la página **\*\*\*TIENDA.1**.

- .- Con fecha 28 de noviembre de 2022, se publica en el foro **\*\*\*PÁGINA WEB** la brecha de datos personales y el enlace al archivo.
- .- Con fecha 24 de junio de 2023, se publica en el foro **\*\*\*FORO.1** la brecha de datos personales y el enlace al archivo.
- .- Con fecha 28 de agosto de 2023, la parte reclamante presenta su reclamación ante la Agencia Española de Protección de Datos.
- .- Con fecha de 27 de octubre de 2023, la AEPD da traslado de la reclamación a la parte reclamada.
- .- Con fecha de 21 de noviembre de 2023, la parte reclamada realiza la notificación de la brecha de seguridad.
- .- Con fecha de 24 de noviembre de 2023, remite a esta Agencia su escrito de respuesta al traslado de la reclamación.
- .- Con fecha de 19 de diciembre de 2023, la parte reclamada comunica lo ocurrido a los afectados mediante el envío de un correo a través de la plataforma de envío **\*\*\*EMPRESA.1**.

#### .-2-. Respecto al traslado de la reclamación

Con fecha de 27 de octubre de 2023, se realiza el traslado de la reclamación a la parte reclamada, la cual remite a esta Agencia su escrito de respuesta con fecha de registro 24 de noviembre de 2023 que incluye el Registro de tratamientos. Asimismo, anexa tres documentos que engloban la siguiente documentación:

- Documento 1: "Informe de un informático interno de la empresa investigada que indica lo que él cree que ha podido suceder".
- Documento 2: Medidas que se aplicaron en la creación de la página web inicial.
- Documento 3: Denuncia ante la Guardia Civil.
- Documento 4: Certificado (expedido por **\*\*\*CONSULTORA.1**) de las Medidas de seguridad actuales implementadas en el eCommerce y en el servidor y de las Medidas extras de seguridad a implementar.
- Documento 5. Borrador de comunicación a los clientes de los hechos acaecidos. Informan (el 24/11/2023) que se pretende enviar "a la mayor brevedad posible."

El escrito de respuesta al traslado de la reclamación aportado por HO incluye, entre otras, las siguientes manifestaciones:

*"2.- La persona de administración que dentro de nuestra empresa se encarga de recepcionar las comunicaciones que nos llegan a través del buzón de comunicaciones, revisó el plazo para contestar y, viendo que era de 30 días, lo archivó para poder analizarlo cuando "quedase menos tiempo para la caducidad del plazo". Lo cual ha provocado, tal como nos ha explicado nuestro abogado, que hayamos incumplido totalmente el plazo que la ley otorga para realizar la oportuna y necesaria notificación de una Brecha de Seguridad ante la Agencia y ponernos a trabajar en este asunto.*

*[...]*

5.- Viendo las fechas que se ponen en la reclamación, comprobamos que aproximadamente en esas fechas se produce una migración de los datos de la antigua página web a la nueva página web, que creo la empresa informática. Ante lo cual deducimos, y actualmente estamos en fase de ampliar nuestra comprobación, que la pérdida de los datos ha podido ocurrir en las fechas que nos indica la persona reclamante y la propia Agencia. Lamentablemente, nos hemos enterado por el escrito de la Agencia. Adjuntamos como Documento 1 un Informe de un informático interno de nuestra empresa que, indagando, indica lo que él cree que ha podido suceder. Este informe se lo hacemos llegar a todos los que están colaborando con la empresa para que podamos avanzar en las investigaciones.

6.- Hemos accedido a los enlaces que nos han hecho llegar por medio de su requerimiento y, por desgracia para nosotros, son datos de nuestros clientes de nuestro comercio online. Es evidente que en la migración realizada por la empresa que lleva nuestra página web, no se pusieron las medidas adecuadas para realizar la misma de forma más segura. En los datos que tenemos, teníamos implantadas medidas de seguridad para evitar un acceso o una pérdida de datos por parte de la empresa informática que nos lleva el comercio electrónico, y nunca tuvimos ningún problema. Adjuntamos como Documento 2, las medidas que por el formato de web se aplicaron en la creación de la página web inicial.

[...]

8.- Como he dicho en algún punto anterior, para nosotros es un tema muy grave que nos haya ocurrido esto. En su momento, y aconsejados por la empresa que montó la tienda on-line, se implementaron medidas, que hemos adjuntado como Documento 2, y lo hicimos precisamente para evitar cualquier pérdida de datos. El pasado lunes procedimos a contratar los servicios de un profesional perito informático, cuyo nombre es A.A.A., para tratar de averiguar exactamente lo que ha podido ocurrir en este caso, y en un primer informe, nos pone una serie de hechos que pueden haberse dado. De forma que tanto este experto en seguridad informática como la empresa que lleva la web (de la cual estamos a la espera de un informe definitivo), coinciden en que pudo haberse dejado sin la seguridad adecuada en el traspaso de los datos.

9.- Hemos procedido a descargar el fichero que contiene los datos viendo que son datos de contacto y los datos de usuario y contraseña de la parte privada de nuestra página web. No existen datos de formas de pago ni datos de tarjetas bancarias. Y tal y como indica el reclamante, puede haber unos (...)datos de usuarios y de clientes. Los datos más sensibles que pueden existir, y no es en todos ellos, es el número de teléfono móvil.

10.- Las consecuencias para las personas afectadas, entendemos desde la empresa que pueden existir si se produce un uso indebido de los datos contenidos en ese fichero por parte de cualquier persona, para poder ponerse en contacto con ellas. En todo caso, desconocemos lo que puede ocurrir cuando hay un fichero de datos de personas en una página como la que nos indicaron. Por parte del perito informático, nos tiene que hacer llegar un informe sobre las posibles medidas a tomar en relación a ese fichero existente en la página que nos señalaron para tratar de eliminarlo.

11.- Por parte de la empresa, y tras el conocimiento de esta fuga, se ha procedido a denunciar ante la Guardia Civil estos hechos, contestando a las preguntas que el agente me fue realizando y, además, aportamos un escrito anexo a la denuncia donde explicamos lo ocurrido de forma un poco más detallada en relación a la información que en ese momento teníamos. [...]

13.- Aparte de la pérdida de los datos, hemos visto que han fallado los protocolos que tenemos implantados en la empresa, así que hemos tratado en estos días de ver qué se puede mejorar en relación a nuestra forma de actuar en cuanto a las comunicaciones de incidencias, notificaciones legales, ejercicio de derechos, llamadas de clientes con incidentes en compras. [...]"

Es destacable que HO reconoce haber "incumplido totalmente el plazo que la ley otorga para realizar la oportuna y necesaria notificación de una Brecha de Seguridad ante la Agencia" (Punto 2), que "no se pusieron las medidas adecuadas para realizar la (migración de la página web) misma de forma más segura" (Punto 6) y que "han fallado los protocolos que tenemos implantados en la empresa" (Punto 13).

#### .-2.1-. Respecto a la explicación de la brecha aportada en la respuesta al traslado.

La parte reclamada proporciona la explicación aportada por el informático de su empresa, basada en una copia de seguridad utilizada durante la migración de la página web.

"Según la notificación recibida, la filtración de la base de datos se produce en noviembre de 2022.

En esas fechas estamos trabajando con una empresa (**\*\*\*CONSULTORA.1**) que nos va a realizar una nueva página web. Concretamente, la ponen online para realizar las primeras pruebas el 3 de noviembre.

Con el cambio de página web, necesitamos que se mantenga el historial de pedidos y usuarios, para tener un control de las ventas realizadas hasta ese momento.

En relación con esto, pensamos que el equipo de informáticos y/o programadores que realizan esta acción de migración de historial de pedidos y usuarios, instala un plug-in en la página que exporta dichos datos de la web antigua, para después poder ser importados en la nueva.

Llegamos a esta conclusión, porque el propio equipo de informáticos de **\*\*\*CONSULTORA.1**, nos dice que han encontrado en una copia de seguridad de esas fechas el archivo en una carpeta de un plug-in utilizado para los fines que hemos citado. También nos dicen que ese archivo ya no está.

Estos archivos quedan exportados en una carpeta que genera dicho plug-in en el backend de la web. En cualquier caso, no es visible ni accesible para los usuarios web.

Durante el tiempo que está el archivo en esa carpeta para la realización de la migración, una persona con conocimientos informáticos avanzados "hacker", ha sido

*capaz de superar las medidas de seguridad de la página web y el alojamiento, entrando en esas carpetas ocultas y hacer una copia del archivo.*

*Pensamos que la persona que descargo el archivo aprovecho este tiempo de migración web para realizar el ataque y robar el archivo.”*

#### *.-2.2-. Respecto a las medidas de seguridad.*

La parte reclamada remite el documento “Medidas que se aplicaron en la creación de la página web inicial”, que es un extracto de la información aportada en la página de (...)

La página ha sido actualizada en abril de 2024, y es incorporada por el inspector al expediente la captura de waybackmachine: (...)

También aporta el documento “Certificado expedido por \*\*\***CONSULTORA.1** de las Medidas de seguridad actuales implementadas en el eCommerce y en el servidor y de las Medidas extras de seguridad a implementar”. En este documento se especifica:

*“Medidas de seguridad actuales implementadas en el eCommerce y en el servidor:*

*- Instalación de la capa de seguridad en Amazon AWS (servidor AWS) donde está instalado el eCommerce y que proporciona servicios que ayudan a proteger los datos, cuentas y cargas de trabajo del acceso no autorizado. Los servicios de protección de datos de AWS contratados proporcionan capacidades de cifrado, administración de claves y descubrimiento de datos confidenciales para proteger los datos, el procesamiento y las cargas de trabajo.*

*- Plugin de seguridad Wordfence instalado sobre el eCommerce que incluye un cortafuegos de punto final (WAF) y un escáner de malware. Cuenta con otras medidas de seguridad como la seguridad de acceso (2FA, página de acceso CAPTCHA, limitar los intentos de acceso}, Tráfico en Vivo, y bloqueo avanzado basado en reglas.*

*- Actualizar los plugins de WordPress de forma regular (de forma semanal) que es una medida de seguridad primordial para el eCommerce. Las actualizaciones de plugins pueden incluir nuevas características o mejoras de rendimiento y seguridad.*

*Medidas extras de seguridad a implementar:*

*Implantar en la infraestructura en la nube de AWS la solución AWS Trusted Advisor que es una herramienta en línea que funciona como un experto en la nube y que puede personalizarse para que le ayude a configurar los recursos conforme a las prácticas recomendadas. Trusted Advisor inspecciona su entorno de AWS para acabar con las deficiencias de seguridad y busca*



*oportunidades para ahorrar dinero, mejorar el rendimiento del sistema y aumentar la fiabilidad.*

*Utilizar técnicas de hash y encriptación para almacenar contraseñas de manera segura. También se pueden implementar políticas de contraseñas fuertes para los clientes.*

*Realizar pruebas de seguridad regulares para identificar y abordar posibles vulnerabilidades en el eCommerce. Utilizar herramientas de escaneo de seguridad y realizar auditorías de manera sistemática.*

*Implementar la autenticación de dos factores (2FA), agrega una capa adicional de seguridad. Requiere que los clientes proporcionen una segunda forma de autenticación, como un código enviado a su teléfono, además de su contraseña, para acceder a su cuenta.”*

### .-2.3-. Respecto al Registro de Actividades de Tratamiento

La parte reclamada aporta en su escrito de respuesta al traslado de la reclamación información contenida en el Registro de Actividades de tratamiento.

### .-3-. Respecto a la notificación de la brecha de seguridad

Tal como explica la parte reclamada en su escrito de respuesta al traslado de la reclamación, la entidad fue consciente de la brecha de datos personales a raíz de la solicitud de información por parte de la AEPD.

Notificado el traslado de la reclamación a la parte reclamada con fecha de 31 de octubre de 2023, HO realiza la notificación a la AEPD de la brecha de seguridad con fecha de 21 de noviembre de 2023.

Los datos relevantes que se comunican en la notificación de la brecha de seguridad a esta Agencia son los siguientes:

- Número aproximado de personas físicas sobre las que recoge, almacena o trata datos personales de otra forma; referido exclusivamente al tratamiento sobre el que se ha producido la brecha de datos personales:(...)
- El tratamiento sobre el que se ha producido la brecha incluye datos de personas únicamente en España, a nivel nacional
- Como consecuencia del incidente, se ha visto afectada la: Confidencialidad
- Los datos no están cifrados de forma segura, anonimizados o protegidos de forma que son ininteligibles para quien haya podido tener acceso o no se puede identificar a las personas.
- Descripción de lo ocurrido.

*“Creemos que, en la migración en el año 2022, de una página web a la nueva página web, se genera un fichero que posteriormente la empresa que llevaba la página no destruye. El responsable de tratamiento, en este momento no tiene relación comercial en esa empresa, incluso se han tenido diversos procesos judiciales en relación a servicios prestados por la misma.”*

- Se va a comunicar la brecha a las personas afectadas, a más tardar en la fecha: 31/12/2023.
- El responsable del tratamiento no tiene designado un DPD.
- No hay implicado un encargado de tratamiento en la brecha de datos personales.
- Las medidas de seguridad implementadas en la organización antes del suceso de la brecha:

*Políticas de protección de datos y seguridad, Formación en protección de datos y seguridad de la información al nivel adecuado, Auditorías periódicas, Control de acceso lógico, Copia de seguridad*

Se podría haber evitado la brecha adoptando alguna medida de seguridad adicional.

El incidente se ha producido por algún fallo, deficiencia o incumplimiento de medidas de seguridad implementadas

- Nuevas medidas de seguridad y las que se hayan actualizado:

*Políticas de protección de datos y seguridad, Formación en protección de datos y seguridad de la información al nivel adecuado, Los sistemas informáticos se mantienen actualizados, Registro de incidentes, Auditorías periódicas, Control de acceso lógico, Copia de seguridad*

#### .-4-. Respecto a la información aportada en la respuesta al requerimiento de información durante la realización de las actuaciones previas de investigación

Con fecha 10 de abril de 2024 se realiza un requerimiento de información a la parte reclamada solicitándole, entre otros puntos, copia de todos los informes aportados por el perito informático experto en seguridad informática con relación a la brecha de seguridad y de todos los informes aportados por la empresa que lleva la web, además de la especificación detallada de las causas que han hecho posible la brecha, teniendo en cuenta su fecha en enero de 2022.

La parte reclamada responde a este requerimiento de información con fecha de registro 24 de abril de 2024, proporcionando la siguiente documentación adjunta a su escrito de respuesta:

- Copia del mail enviado a clientes (19/12/2023).



- Copia de todos los contratos con **\*\*\*CONSULTORA.1** y comunicaciones por mail en relacion a la brecha
  - o AMS para Ecommerce **\*\*\*TIENDA.1**. Fecha 24/04/23.
  - o Hosting Cloud AWS - Servicio Hosting AWS / Soporte y mantenimiento. Fecha 03/03/22.
  - o Infraestructura Cloud y Mejoras – Proyecto. Fecha 03/03/22.
  - o Informe de progreso Diciembre 2021 – Enero 2022. Fecha 31/01/22.
  - o Comunicaciones
- Auditoria de seguridad realizada por **\*\*\*EMPRESA.2**, que incluye el informe pericial de Asociación Nacional de Tasadores y Peritos Judiciales Informáticos - ANTPJI

#### .-4.1-. Respecto a la comunicación realizada a los afectados

HO manifiesta que comunicaron lo ocurrido a los afectados mediante el envío de un correo a cada uno de ellos a través de la plataforma de envío **\*\*\*EMPRESA.1**. Aporta la copia del mail enviado a clientes por **\*\*\*EMPRESA.1**, que tiene fecha 19/12/2023.

#### .-4.2-. Respecto al mantenimiento de los Sistemas de Información afectados por la brecha, realizado por terceras compañías

La parte reclamada indica en su escrito de respuesta al requerimiento que *“Ante la inseguridad que nos pareció demostrar en su momento la anterior empresa que nos llevaba la empresa hasta el año 2021, decidimos preguntar a la entidad **\*\*\*CONSULTORA.1**.*

*En el caso de la compañía que realiza el mantenimiento de la página web, esta empresa, comenzó con un proyecto en DICIEMBRE 2021, que fue cuando se firmó el primer contrato, hasta la ACTUALIDAD. **\*\*\*CONSULTORA.1**, ha estado trabajando y ayudándonos en tratar de cumplir con todo lo que conlleva nuestra página web.”*

Proporciona copia de los siguientes contratos con **\*\*\*CONSULTORA.1**, ya mencionados anteriormente:

- AMS para Ecommerce **\*\*\*TIENDA.1**. Fecha 24/04/23.
- Hosting Cloud AWS - Servicio Hosting AWS / Soporte y mantenimiento. con Fecha 03/03/22.
- Infraestructura Cloud y Mejoras – Proyecto. Fecha 03/03/22.
- Informe de progreso Diciembre 2021 – Enero 2022 Fecha 31/01/22.

La importancia de este último informe radica en que la denunciada brecha de seguridad ocurrió precisamente durante y después del tramo temporal (diciembre 2021-enero 2022), al que apunta este informe de **\*\*\*CONSULTORA.1**.

El informe consta de una lista de Tareas Realizadas, Tareas Previstas y Observaciones futuras, a saber:

#### *Tareas Realizadas*

- Puesta en producción de nueva web de **\*\*\*TIENDA.1**.
- Desarrollos realizados (...).
- Actualización de catálogo, usuarios y pedidos, desde la web anterior de producción.
- Integración de desarrollos.
- Diagnósticos de infraestructura y aumento de recursos.
- Esfuerzo en horas empleadas: 108 horas.
- Corrección de reportes de funcionamiento.

#### *Tareas Previstas*

- Presentación de oferta de infraestructura cloud y mejoras en la web para Febrero de 2022, bajo responsabilidad de **\*\*\*CONSULTORA.1**.

#### *Observaciones*

- Envío de informes mensuales detallando avances en el proyecto.
- Próximo paso: llevar la web a infraestructura cloud auto-escalable.
- **\*\*\*CONSULTORA.1** se compromete a preparar una oferta en este sentido, para presentar al cliente en febrero de 2022, con propuestas concretas de mejoras en el funcionamiento y uso de la web.

Solicitado el contrato de encargado o subencargado de tratamiento con terceras compañías, HO refiere que **\*\*\*CONSULTORA.1** “No tratan datos de clientes en su trabajo en la página web. Por esto, no han sido considerados como encargados de tratamiento, ni como subencargados.”

#### .-4.3-. Respecto a las comunicaciones con **\*\*\*CONSULTORA.1**

La parte reclamada proporciona las comunicaciones por mail con la empresa **\*\*\*CONSULTORA.1** en relación a la brecha. Lo más relevante se reproduce en el correo con fecha 8 de noviembre de 2023:

*“Hemos hecho un análisis exhaustivo tirando de copias de seguridad y hemos visto en un copia antigua que existía un fichero con todos los datos en la carpeta uploads. La carpeta se llamaba (...), y mirando por internet parece que es un plugin que exporta los usuarios de la BBDD.*

*La verdad es que no tenemos constancia de ese plugin ya que no está instalado ni lo hemos visto en las copias de seguridad.*

*También hemos visto que a día de hoy el fichero ya no existe, por lo que entendemos que el riesgo está mitigado.”*

A petición de HO, **\*\*\*CONSULTORA.1** remite con fecha 23 de noviembre de 2023 un informe detallado de las medidas de seguridad actuales de la web y del servidor y las posibles medidas extra de seguridad que se podrían implementar para que el robo de información no vuelva a producirse, enviado a esta Agencia en la respuesta al traslado de la reclamación, Certificado expedido por **\*\*\*CONSULTORA.1** de las Medidas de seguridad actuales implementadas en el eCommerce y en el servidor y de las Medidas extras de seguridad a implementar.

En este documento se especifican las medidas de seguridad que han sido detalladas previamente en el apartado 2.2 del informe de las actuaciones previas de investigación.

#### .-4.4-. Respecto a los datos personales comprometidos en la brecha

La parte reclamada indica en su escrito de respuesta que los tipos de datos afectados son los siguientes:

“ID, customer id, userg login, user pass (cifrado (...)), user nice name, user email, user url, user registered, display name, first name, last name, user status, roles, nickname, descripcion, rich editing, syntax highlighting, admin color, use ssl, show admin bar front loca/e, wp user leve/, dismissed wp pointers show welcome panel session token, last update, billing first name, billing last name, billing company, billing email, billing phone, billing address 1, billing adress 2, billing postcode, billing city, billing state, billing conuntry, shipping first name, shipping last name, shipping company, shipping phone, shipping adress 1, shipping addres2, ahipping postcode, shipping city, shipping state, shipping country,”

Los tipos de datos son los incluidos en la cabecera del fichero Excel descargado [Datos\_\*\*\***FORO.1**].

HO continúa informando que no existen datos de pago ni datos de tarjetas bancarias afectados por la brecha y que las contraseñas comprometidas se encuentran cifradas de forma segura. La base de datos utiliza un cifrado (...) para las contraseñas de los usuarios.

Respecto a la cantidad total de personas afectadas, indica que han sido (...) personas, de las cuales hay datos de 45 personas de países externos a España:

*“En el fichero constaban los datos de 45 clientes con residencia transfronteriza, de ellos son:*

- 3 de Bélgica; 5 de Alemania; 4 de Francia;1 de Irlanda; 1 de Italia; 2 de Holanda;
- 9 de Portugal;1 de Suecia;
- 2 de Andorra; 2 de Suiza 3 de Estados Unidos. 4 de Gran Bretaña.
- 3 de Australia; 1 de Costa Rica1 de Puerto Rico; 1 de Guatemala; 2 de México

*Los clientes extranjeros la mayoría pertenecen a la Unión Europea, concretamente a Bélgica, Alemania, Francia, Irlanda, Italia, Holanda, Portugal y Suecia haciendo un total de 26 clientes.”*

Con relación a la utilización por terceros o la posible publicación en Internet de los datos personales obtenidos a causa de la brecha, HO indica que no tiene conocimiento de una utilización posterior y aporta un informe pericial en el que el Perito y el Auditor coinciden en que no existen indicios de publicación en internet e indexación de buscadores.

#### .-4.5-. Respecto de la seguridad de los tratamientos de datos personales

En su escrito de respuesta al requerimiento HO aporta una captura (sin fecha) del Análisis de riesgos sobre la actividad de tratamiento que ha sufrido la brecha, en la que recoge el ciclo de vida de los datos afectados e identifica los siguientes riesgos:

- 7.2.1 Riesgos Asociados a la Legitimación de los Tratamientos
- 7.2.2 Riesgos Asociados a Cesiones de Datos Personales
- 7.2.3 Riesgos Asociados a la No Transparencia de los Tratamientos
- 7.2.4 Riesgos Asociados a la Seguridad de los Datos
- 7.2.5 Riesgos Asociados al Incumplimiento del Principio de Minimización y Licitud
- 7.2.6 Riesgos Asociados a la Prestación de Servicios

(...) analiza los factores de riesgo identificados y calcula el riesgo inherente mediante la fórmula:  $\text{RIESGO} = \text{PROBABILIDAD} \times \text{IMPACTO}$ , resultando:

- 7.2.1 R.A. Legitimación de los Tratamientos: Medio
- 7.2.2 R.A. Cesiones de Datos Personales: Medio
- 7.2.3 R.A. No Transparencia de los Tratamientos: Bajo
- 7.2.4 R.A. Seguridad de los Datos: Medio
- 7.2.5 R.A. Incumplimiento del Principio de Minimización y Licitud: Bajo
- 7.2.6 R.A. Prestación de Servicios: Alto

*“Como se ve en la apreciación de los riesgos, consideramos el punto 6, riesgo asociado a la PRESTACION DE SERVICIOS, en su momento como ALTO. En su momento como medidas, para minimizarlo, y al no considerar como ENCARGADO DE TRATAMIENTO DE DATOS, NI SUBENCARGADO a la empresa que llevaba la página web en su momento, no se le dio a firmar más contrato que el que se tenía expedido por ellos para realizar las labores en la página web. Como empresa pequeña, no tenemos el suficiente conocimiento para poder saber si un informático o una empresa informática en una migración, ha podido dejar un fichero con esos datos. Este hecho del cual tuvimos conocimiento en su primer requerimiento, y sumando otras cosas que se incumplieron por esta entidad anterior, decidimos cambiar de empresa informática tal y como aportamos en los contratos con la entidad **\*\*\*CONSULTORA.1.**”*

Solicitada copia de las Evaluaciones de Impacto de los tratamientos donde se ha producido la violación de seguridad de los datos personales, HO responde:

*“No se consideró hacer en su momento una Evaluación de Impacto, dado que los datos que se solicitaban en nuestra página web, no son datos que en este tratamiento pudiesen dar lugar (en principio) a ninguna de las exposiciones que se dan en el Reglamento, en su considerando 75.*

*Bien es cierto que es una forma de poder demostrar que se ha analizado el tratamiento y el riesgo, y de dejar las evidencias para que, si ocurre lo que nos ha ocurrido, con el Informe de Evaluación de Impacto, en este momento podríamos haber podido cumplir con la Agencia presentándolo. Pero en el momento que esto ocurrió, reitero, nuestra empresa no tuvo conocimiento de los hechos. Dado que como reconocimos en nuestro anterior escrito, lamentablemente tuvimos que esperar a su escrito para tener conocimiento de estos hechos.”*

Con relación al motivo por el cual las medidas de seguridad implantadas no han impedido el incidente de seguridad, HO indica:

*“Siempre entendimos que la empresa informática, debería haber cumplido con su cometido de forma segura. En ningún caso se nos ha pasado por la cabeza el hecho que nos ha ocurrido, como empresa pequeña, jamás se nos hubiese imaginado que esto nos podría pasar a nosotros.*

*Como hemos indicado anteriormente, otras cosas nos llevaron a la desconfianza y sumado a este hecho hace que ahora tengamos este aspecto bajo una visión microscopia, porque evidentemente no puede volver a ocurrir, no por un motivo de cumplimiento legal (que debemos cumplir), sino porque los clientes son nuestra empresa.”*

En su escrito de respuesta al requerimiento, HO continúa explicando los protocolos que tiene implementados cuando se detecta una brecha de seguridad, especificando que *“Cuando un empleado/a nuevo/a, entra en nuestra entidad, en este momento y desde el conocimiento de estos hechos, se le entrega un “Documento de Bienvenida”, donde además de indicarle las medidas que debe adoptar en relación a aspectos que tienen que ver con la confidencialidad y tratamiento de los datos a los que accede por su trabajo, se les entrega esta documentación para que puedan actuar en determinadas situaciones (Acoso, Brechas, Incidencias, ... etc).”*

La parte reclamada adjunta una captura del protocolo relativo a las BRECHAS.

#### .-4.6-. Respecto a la Auditoria de seguridad y el Informe pericial

En su respuesta al traslado de la reclamación HO refiere haber contratado los servicios de un profesional perito informático para tratar de averiguar exactamente lo que ha podido ocurrir. Solicitado el informe de dicho experto, la parte reclamada explica: *“hemos contratado a profesionales desde el primer momento, primero **A.A.A.**, experto en Seguridad Informática, que, por motivos personales, tuvo que dejar de trabajar en la resolución de este problema, pero nos recomendó a una empresa que es la que nos ha estado ayudando de forma externa, que es **\*\*\*EMPRESA.2 (B.B.B.)** y el experto en Seguridad Informática **C.C.C.**, que nos asesoran en la materia que nosotros no conocemos, y nos dan más seguridad en que podamos controlar todo lo que se hace en nuestra página web y además contar con ellos en la futura página web. Además de ayudarnos en este asunto.”*

HO aporta el documento “Auditoria de seguridad” realizada por **\*\*\*EMPRESA.2**, que incluye el informe pericial de Asociación Nacional de Tasadores y Peritos Judiciales Informáticos – ANTPJI.

El objeto de la Auditoría técnica es examinar la seguridad de la información de la página web **\*\*\*TIENDA.1** e informar sobre los aspectos señalados por la AEPD, en su requerimiento de información. La metodología está dividida en tres secciones: informe de dónde se ha podido producir la brecha de seguridad, auditoría del sistema informático actual y resolución de los puntos de la AEPD.

#### **“PARTE I. INFORME DE DÓNDE SE HA PODIDO PRODUCIR LA BRECHA DE SEGURIDAD.**

*Para lo cual se facilitará a los auditores los siguientes datos en producidos en el periodo de 1 de diciembre de 2021 y 31 de enero de 2022:*

- 1. Copia de los registros de los logs de accesos a la página web vieja e informe de actividad de usuarios*
- 2. Copia de los de los logs de accesos a la página web nueva e informe de actividad de los usuarios.*
- 3. Backups de la página nueva y de la página vieja.*
- 4. Intercambio epistolar entre la dirección y el departamento informático de **DISEÑOS HERMANAS ORTIZ CAÑÓN (\*\*TIENDA.1)** y los encargados de tratamiento que daban hospedaje a la página web.*
- 5. Copia de los contratos con los encargados de tratamiento y el servicio de hospedaje.*

*[...]*

#### **CONCLUSIONES**

*D. **B.B.B.**, concluye que:*

*“Durante la Auditoria no se han podido obtener evidencias de cómo se extrajo el fichero de clientes de **\*\*TIENDA.1** a pesar de haber buscado dentro del sistema informático de la empresa.*

*Asimismo, ni **C.C.C.** ni **B.B.B.** han podido encontrar el fichero comprometido en la Dark Web ni en Internet.*

*No podemos establecer cómo se produjo la filtración, siendo plausible la explicación dada por la compañía”.*

#### **PARTE II. AUDITORÍA DEL SISTEMA INFORMÁTICO ACTUAL.**

*Todos los plugins son de empresas de solvencia como (...).*

*[...]*

#### **CONCLUSIÓN:**

*En la actualidad la página web **\*\*TIENDA.1** utiliza la tecnología de Word-Press en la forma recomendada, con minimización de Plugins y de fuentes confiables, control de accesos y actualizaciones automática. Sin embargo, la seguridad en internet, no es plena ni está garantizada.*

*[...]*

#### **PARTE III. RESOLUCIÓN DE LOS PUNTOS DE LA AEPD**

En este apartado del documento [Resp#1\_Doc#3], se recoge la información que se ha explicado a lo largo del presente informe. Reiteran la conclusión alcanzada:

*“Durante la Auditoria no se han podido obtener evidencias de cómo se extrajo el fichero de clientes de **\*\*TIENDA.1** a pesar de haber buscado dentro del sistema informático de la empresa. Asimismo, ni D. **C.C.C.** ni **B.B.B.** han podido encontrar el fichero comprometido en la Dark Web ni en Internet.*

*No podemos establecer cómo se produjo la filtración, siendo plausible la explicación dada por la compañía de un posible descuido en el cambio del sistema de información de la página web”.*



*D. B.B.B., firma el presente Dictamen, declara que está capacitado como Experto en Derecho Informático y que cuenta con el título y certificación de Auditor Líder de Aenor en la ISO 27001.”*

Los informes contemplan en sus investigaciones enero 2022 como fecha de la brecha de seguridad y concluyen que no pueden establecer cómo se produjo la filtración.

QUINTO: De acuerdo con el informe recogido de la herramienta AXESOR, la entidad HO tiene un volumen de negocios de (...)euros en el año 2023.

## FUNDAMENTOS DE DERECHO

### I

#### Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), es competente para iniciar y resolver este procedimiento la Directora de la Agencia Española de Protección de Datos.

### II

#### Procedimiento

El artículo 63.2 de la LOPDGDD determina que: *“Los procedimientos tramitados por la Agencia Española de Protección de Datos se regirán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos”.*

De acuerdo con el artículo 64 de la LOPDGDD, y teniendo en cuenta las características de las presuntas infracciones cometidas se inicia un procedimiento sancionador.

El procedimiento tendrá una duración máxima de doce meses a contar desde la fecha del acuerdo de inicio. Transcurrido ese plazo se producirá su caducidad y, en consecuencia, el archivo de actuaciones, de conformidad con lo establecido en el artículo 64 de la LOPDGDD.

Si en el plazo estipulado no efectuara alegaciones a este acuerdo de inicio, el mismo podrá ser considerado propuesta de resolución, según lo establecido en el artículo 64.2.f) de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en lo sucesivo, LPACAP).

### III

#### Cuestiones previas

En el presente caso, de acuerdo con lo establecido en el artículo 4.1 y 4.2 del RGPD, consta la realización de un tratamiento de datos personales, toda vez que HO realiza, entre otros tratamientos la recogida y conservación de datos personales de personas físicas, con la finalidad de la gestión de los datos introducidos por sus clientes en los formularios de recogida de datos de la página web, así como para la gestión de compras de dichos clientes y la entrega de pedidos.

A esos efectos, realiza el tratamiento de datos como el nombre, apellidos, dirección postal, dirección electrónica, número de teléfono, usuario y contraseña de las cuentas, y datos de facturación

HO realiza esta actividad en su condición de responsable del tratamiento, dado que es quien determina los fines y medios de tal actividad, en virtud del artículo 4.7 del RGPD.

#### IV

##### Obligación incumplida. Integridad y confidencialidad

La letra f) del artículo 5.1 del RGPD propugna:

*"1. Los datos personales serán:*

*(...)*

*f) tratados de tal manera que se garantice una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas («integridad y confidencialidad»).*"

En el presente caso, constan evidencias en el expediente de la publicación en el foro **\*\*\*FORO.1**, con fecha 24 de junio de 2023, que refiere a una publicación en **\*\*\*PÁGINA WEB** con fecha 28 de noviembre de 2022, que indica que en enero de 2022 la tienda Online de ropa **\*\*\*TIENDA.1** sufrió una brecha de datos personales que afectó a (...) clientes.

Una vez descargado el fichero **[Datos\_\*\*\*FORO.1]**, se analizan los datos contenidos en el Excel del archivo descargado. Los datos contenidos en el Excel incluyen:

- Nombre y apellidos.
- Dirección postal y electrónica
- Datos de usuario y contraseña de su cuenta (cifrado)
- Datos de facturación: Nombre, apellidos, dirección postal y teléfono

Se comprueba que en el fichero Excel hay un total de 20570 entradas, de las cuales dos filas contienen la información de la parte reclamante, en concreto *las filas: 8497 y 17571*.

Asimismo, de acuerdo con las gestiones realizadas por la inspección y las manifestaciones de la parte reclamada, consta en el procedimiento lo siguiente:

- La brecha de datos personales se habría producido, conforme se declara por la parte reclamada en su notificación a la AEPD, en "noviembre de 2022"

- Se ha comprobado que los datos estaban publicados en sendos sitios de Internet en fechas de noviembre de 2022 y junio de 2023.
- El traslado a la parte reclamada de la reclamación se realizó el 27/10/2023, es decir, prácticamente un año después
- En su contestación a dicho traslado, HO declara que no conoció que la brecha se había producido hasta recibir la reclamación a través de la AEPD. En consecuencia, existen indicios de que los datos podían resultar accesibles por período de un año antes de que el responsable del tratamiento se percatase de la pérdida de confidencialidad.

Adicionalmente, y en lo que afecta a la citada pérdida de confidencialidad de los datos filtrados, en el informe de las actuaciones previas de investigación se refleja que, a excepción de las contraseñas y datos de facturación, los datos no estaban cifrados de forma segura, anonimizados o protegidos de forma que fueran ininteligibles para quien haya podido tener acceso.

Por tanto, de conformidad con las evidencias de las que se dispone en este momento de acuerdo de inicio de procedimiento sancionador, se considera que los hechos conocidos podrían ser constitutivos de una infracción, imputable a HO, por vulneración del artículo transcrito anteriormente.

## V

### Tipificación de la infracción del artículo 5.1.f) del RGPD y calificación a efectos de prescripción

El artículo 83.5 del RGPD tipifica como infracción administrativa la vulneración de los artículos siguientes, que se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 20.000.000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

*"a) los principios básicos para el tratamiento, incluidas las condiciones para el consentimiento a tenor de los artículos 5, 6, 7 y 9;"*

Por su parte, la LOPDGDD en su artículo 71, Infracciones, señala que:

*"Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica".*

A los solos efectos del plazo de prescripción, el artículo 72.1 de la LOPDGDD establece lo siguiente:

*"En función de lo que establece el artículo 83.5 del Reglamento (UE) 2016/679 se consideran muy graves y prescribirán a los tres años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:*

*a) El tratamiento de datos personales vulnerando los principios y garantías establecidos en el artículo 5 del Reglamento (UE) 2016/679."*

## VI

### Propuesta de sanción por la vulneración del artículo 5.1.f) RGPD

A fin de determinar la multa administrativa a imponer se han de observar las previsiones de los artículos 83.1 y 83.2 del RGPD, preceptos que señalan:

*"1. Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 9 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias.*

*2. Las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j). Al decidir la imposición de una multa administrativa y su cuantía en cada caso individual se tendrá debidamente en cuenta:*

- a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido;*
- b) la intencionalidad o negligencia en la infracción;*
- c) cualquier medida tomada por el responsable o encargado del tratamiento para paliar los daños y perjuicios sufridos por los interesados;*
- d) el grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32;*
- e) toda infracción anterior cometida por el responsable o el encargado del tratamiento;*
- f) el grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción;*
- g) las categorías de los datos de carácter personal afectados por la infracción;*
- h) la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida;*
- i) cuando las medidas indicadas en el artículo 58, apartado 2, hayan sido ordenadas previamente contra el responsable o el encargado de que se trate en relación con el mismo asunto, el cumplimiento de dichas medidas;*
- j) la adhesión a códigos de conducta en virtud del artículo 40 o a mecanismos de certificación aprobados con arreglo al artículo 42, y*
- k) cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción".*

Por su parte, el artículo 76 "Sanciones y medidas correctivas" de la LOPDGDD dispone:

*“1. Las sanciones previstas en los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679 se aplicarán teniendo en cuenta los criterios de graduación establecidos en el apartado 2 del citado artículo.*

*2. De acuerdo a lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta:*

- a) El carácter continuado de la infracción.*
- b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.*
- c) Los beneficios obtenidos como consecuencia de la comisión de la infracción.*
- d) La posibilidad de que la conducta del afectado hubiera podido inducir a la comisión de la infracción.*
- e) La existencia de un proceso de fusión por absorción posterior a la comisión de la infracción, que no puede imputarse a la entidad absorbente.*
- f) La afectación a los derechos de los menores.*
- g) Disponer, cuando no fuere obligatorio, de un delegado de protección de datos.*
- h) El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos, en aquellos supuestos en los que existan controversias entre aquellos y cualquier interesado”.*

En el presente caso, considerando la gravedad de la posible infracción, atendiendo especialmente a las consecuencias que su comisión provoca en los afectados, correspondería la imposición de multa, además de la adopción de medidas, si procede.

La multa que se imponga deberá ser, en cada caso individual, efectiva, proporcionada y disuasoria, conforme a lo establecido en el artículo 83.1 del RGPD. Para garantizar estos principios, se considera, con carácter previo, el volumen de negocio de HO, de (...) euros en el año 2023.

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, de conformidad con las evidencias de que se dispone en el presente momento de acuerdo de inicio de procedimiento sancionador, y sin perjuicio de lo que resulte de la instrucción, se considera que procede graduar la sanción a imponer de acuerdo con las circunstancias siguientes, contempladas en los preceptos antes citados.

Con carácter previo, se estima que concurren las circunstancias siguientes:

La naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido (artículo 83.2, letra a), del RGPD).

En primer lugar, conforme declara la propia parte reclamada, se han visto afectados los datos personales de un total de (...) registros, que se corresponderían con sus clientes. Además, los riesgos de la exposición de dichos datos se habrían incrementado teniendo en cuenta que habría transcurrido casi un año desde que se produjo la brecha hasta que el responsable tuvo conocimiento de la misma, lo que le impidió adoptar las medidas necesarias para evitar que se volviera a producir.

Asimismo, se considera como factor de graduación en calidad de agravante la vinculación de la actividad del infractor con la realización de tratamientos de datos personales (artículo 76.2, letra b), de la LOPDGD). El responsable del tratamiento es una empresa dedicada al comercio electrónico a través de la web **\*\*\*TIENDA.1** y dispone de gran cantidad de clientes, a la luz del número de afectados (...)

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD y 76.2 de la LOPDGD con respecto a la infracción cometida al vulnerar lo establecido en el artículo 5.1.f) del RGPD, permite fijar inicialmente una sanción de multa administrativa de 20.000,00 euros.

## VII

### Obligación incumplida. Seguridad del tratamiento

El artículo 32 del RGPD estipula lo siguiente:

*"1. Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:*

- a) la seudonimización y el cifrado de datos personales;*
- b) la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;*
- c) la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico;*
- d) un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.*

*2. Al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, en particular como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.*

*3. La adhesión a un código de conducta aprobado a tenor del artículo 40 o a un mecanismo de certificación aprobado a tenor del artículo 42 podrá servir de elemento para demostrar el cumplimiento de los requisitos establecidos en el apartado 1 del presente artículo.*

*4. El responsable y el encargado del tratamiento tomarán medidas para garantizar que cualquier persona que actúe bajo la autoridad del responsable o del encargado y tenga acceso a datos personales solo pueda tratar dichos datos siguiendo instrucciones del responsable, salvo que esté obligada a ello en virtud del Derecho de la Unión o de los Estados miembros."*

El artículo 32 no establece medidas de seguridad estáticas, sino que corresponde a responsables y encargados determinar aquellas medidas de seguridad que son



necesarias para garantizar la confidencialidad, la integridad y la disponibilidad de los datos personales, por lo tanto, un mismo tratamiento de datos puede implicar medidas de seguridad distintas en función de las especificidades concretas en las que tiene lugar dicho tratamiento de datos.

En consonancia con estas previsiones, el Considerando 75 del RGPD establece:

*Los riesgos para los derechos y libertades de las personas físicas, de gravedad y probabilidad variables, pueden deberse al tratamiento de datos que pudieran provocar daños y perjuicios físicos, materiales o inmateriales, en particular en los casos en los que el tratamiento pueda dar lugar a problemas de discriminación, usurpación de identidad o fraude, pérdidas financieras, daño para la reputación, pérdida de confidencialidad de datos sujetos al secreto profesional, reversión no autorizada de la seudonimización o cualquier otro perjuicio económico o social significativo; en los casos en los que se prive a los interesados de sus derechos y libertades o se les impida ejercer el control sobre sus datos personales; en los casos en los que los datos personales tratados revelen el origen étnico o racial, las opiniones políticas, la religión o creencias filosóficas, la militancia en sindicatos y el tratamiento de datos genéticos, datos relativos a la salud o datos sobre la vida sexual, o las condenas e infracciones penales o medidas de seguridad conexas; en los casos en los que se evalúen aspectos personales, en particular el análisis o la predicción de aspectos referidos al rendimiento en el trabajo, situación económica, salud, preferencias o intereses personales, fiabilidad o comportamiento, situación o movimientos, con el fin de crear o utilizar perfiles personales; en los casos en los que se traten datos personales de personas vulnerables, en particular niños; o en los casos en los que el tratamiento implique una gran cantidad de datos personales y afecte a un gran número de interesados. (el subrayado es nuestro)*

Asimismo, el Considerando 83 del RGPD establece:

*A fin de mantener la seguridad y evitar que el tratamiento infrinja lo dispuesto en el presente Reglamento, el responsable o el encargado deben evaluar los riesgos inherentes al tratamiento y aplicar medidas para mitigarlos, como el cifrado. Estas medidas deben garantizar un nivel de seguridad adecuado, incluida la confidencialidad, teniendo en cuenta el estado de la técnica y el coste de su aplicación con respecto a los riesgos y la naturaleza de los datos personales que deban protegerse. Al evaluar el riesgo en relación con la seguridad de los datos, se deben tener en cuenta los riesgos que se derivan del tratamiento de los datos personales, como la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos, susceptibles en particular de ocasionar daños y perjuicios físicos, materiales o inmateriales. (el subrayado es nuestro)*

La seguridad de los datos requiere la aplicación de medidas técnicas u organizativas apropiadas en el tratamiento de los datos personales para proteger dichos datos contra el acceso, uso, modificación, difusión, pérdida, destrucción o daño accidental, no autorizado o ilícito. En este sentido, las medidas de seguridad son claves a la hora

de garantizar el derecho fundamental a la protección de datos. No es posible la existencia del derecho fundamental a la protección de datos personales si no es posible garantizar la confidencialidad, la integridad y la disponibilidad de estos.

No debe olvidarse que, de conformidad con el artículo 32.1 del RGPD citado, las medidas técnicas y organizativas a aplicar para garantizar un nivel de seguridad adecuado al riesgo deben tener en cuenta el estado de la técnica, los costes de aplicación, la naturaleza, el alcance, el contexto y los fines del tratamiento, así como los riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas.

Por tanto, HO, a la hora de evaluar los riesgos y determinar las medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo para los derechos y libertades de las personas físicas de los tratamientos de datos que realiza en calidad de responsable del tratamiento, está obligada a tener en cuenta la concreta actividad que supone su negocio, que conlleva tratar datos personales de forma continua y a gran escala (numerosos datos a recoger, procesar, almacenar...); la tipología de datos tratados (identificativos, de contacto, cuentas corrientes, etc); el contexto (existencia de aplicativos web en internet (es decir, en un entorno no aislado, lo que conlleva riesgos derivados de la propia interconectividad que supone la red, los cuales deben atenderse de forma especializada; existencia de una base de datos común a varias empresas con exigencias de separación física o lógica).

Por ello, derivado de la actividad a la que se dedica, la parte reclamada está obligada a realizar de forma muy especializada un análisis de los riesgos y una implantación de medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo de su actividad para los derechos y libertades de las personas.

En el presente caso, en respuesta a la actuación previa de investigación, HO aportó el documento “Medidas que se aplicaron en la creación de la página web inicial”, que es un extracto de la información aportada en la página de (...) y el documento “Certificado expedido por **\*\*\*CONSULTORA.1** de las Medidas de seguridad actuales implementadas en el eCommerce y en el servidor y de las Medidas extras de seguridad a implementar”, en el que se especifican las medidas de seguridad implementadas en el momento de emisión del informe (noviembre de 2023) y otras que se recomienda implementar.

De acuerdo con HO, su hipótesis sobre el motivo por el que pudo producirse la brecha sería la instalación de un plug-in en la web para exportar el historial de pedidos y usuarios de su anterior web para migrarlo a la actual, en el que quedaría alojado el archivo objeto de la brecha, de tal modo que, durante los trabajos de migración, alguien podría haber accedido a dicho archivo.

En cualquiera de los casos, en la fecha en que se produce la brecha, no estarían implementadas medidas de seguridad como las siguientes:

- Implantar en la infraestructura en la nube de AWS la solución AWS Trusted Advisor o similares.

- Utilizar técnicas de hash y encriptación para almacenar contraseñas de manera segura.
- Realizar pruebas de seguridad regulares para identificar y abordar posibles vulnerabilidades en el eCommerce.
- Implementar la autenticación de dos factores

Por tanto, de conformidad con las evidencias de las que se dispone en este momento de acuerdo de inicio de procedimiento sancionador, se considera que los hechos conocidos podrían ser constitutivos de una infracción, imputable a HO, por vulneración del artículo transcrito anteriormente.

### VIII

#### Tipificación de la infracción del artículo 32 del RGPD y calificación a efectos de prescripción

El artículo 83.4 del RGPD tipifica como infracción administrativa la vulneración de los artículos siguientes, se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10.000.000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

*"a) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43"*

Por su parte, la LOPDGDD en su artículo 71, Infracciones, señala que:

*"Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica".*

A los solos efectos del plazo de prescripción, el artículo 73 de la LOPDGDD establece lo siguiente:

*"En función de lo que establece el artículo 83.4 del Reglamento (UE) 2016/679 se consideran graves y prescribirán a los dos años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:*

*f) La falta de adopción de aquellas medidas técnicas y organizativas que resulten apropiadas para garantizar un nivel de seguridad adecuado al riesgo del tratamiento, en los términos exigidos por el artículo 32.1 del Reglamento (UE) 2016/679."*

### IX

#### Propuesta de sanción por vulneración del artículo 32 del RGPD

A fin de determinar la multa administrativa a imponer se han de observar las previsiones de los artículos 83.1 y 83.2 del RGPD, preceptos que señalan:

*“1. Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 9 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias.*

*2. Las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j). Al decidir la imposición de una multa administrativa y su cuantía en cada caso individual se tendrá debidamente en cuenta:*

- a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido;*
- b) la intencionalidad o negligencia en la infracción;*
- c) cualquier medida tomada por el responsable o encargado del tratamiento para paliar los daños y perjuicios sufridos por los interesados;*
- d) el grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32;*
- e) toda infracción anterior cometida por el responsable o el encargado del tratamiento;*
- f) el grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción;*
- g) las categorías de los datos de carácter personal afectados por la infracción;*
- h) la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida;*
- i) cuando las medidas indicadas en el artículo 58, apartado 2, hayan sido ordenadas previamente contra el responsable o el encargado de que se trate en relación con el mismo asunto, el cumplimiento de dichas medidas;*
- j) la adhesión a códigos de conducta en virtud del artículo 40 o a mecanismos de certificación aprobados con arreglo al artículo 42, y*
- k) cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción”.*

Por su parte, el artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD dispone:

*“1. Las sanciones previstas en los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679 se aplicarán teniendo en cuenta los criterios de graduación establecidos en el apartado 2 del citado artículo.*

*2. De acuerdo a lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta:*

- a) El carácter continuado de la infracción.*
- b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.*
- c) Los beneficios obtenidos como consecuencia de la comisión de la infracción.*

- d) La posibilidad de que la conducta del afectado hubiera podido inducir a la comisión de la infracción.*
- e) La existencia de un proceso de fusión por absorción posterior a la comisión de la infracción, que no puede imputarse a la entidad absorbente.*
- f) La afectación a los derechos de los menores.*
- g) Disponer, cuando no fuere obligatorio, de un delegado de protección de datos.*
- h) El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos, en aquellos supuestos en los que existan controversias entre aquellos y cualquier interesado”.*

En el presente caso, considerando la gravedad de la posible infracción, atendiendo especialmente a las consecuencias que su comisión provoca en los afectados, correspondería la imposición de multa, además de la adopción de medidas, si procede.

La multa que se imponga deberá ser, en cada caso individual, efectiva, proporcionada y disuasoria, conforme a lo establecido en el artículo 83.1 del RGPD. Para garantizar estos principios, se considera, con carácter previo, el volumen de negocio de HO, de (...) euros en el año 2023.

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, de conformidad con las evidencias de que se dispone en el presente momento de acuerdo de inicio de procedimiento sancionador, y sin perjuicio de lo que resulte de la instrucción, se considera que procede graduar la sanción a imponer de acuerdo con las circunstancias siguientes, contempladas en los preceptos antes citados.

Con carácter previo, se estima que concurren las circunstancias siguientes:

En primer lugar, cabría considerar la existencia de negligencia, en la medida en que medidas básicas como la encriptación o la autenticación de doble factor no habían sido adoptadas en el momento en que se produce la brecha.

En segundo lugar, la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido (artículo 83.2, letra a), del RGPD). En este caso concreto, habrían quedado expuestos datos personales de (...) registros correspondientes a los clientes de HO, consistentes en sus nombre y apellidos, dirección postal y electrónica, datos de usuario y contraseña de su cuenta (cifrado) y datos de facturación (nombre, apellidos, dirección postal y teléfono). Dichos datos habrían estado expuestos durante más de un año.

Se considera como factor de graduación en calidad de agravante la vinculación de la actividad del infractor con la realización de tratamientos de datos personales (artículo 76.2, letra b), de la LOPDGDD). El responsable del tratamiento es una empresa dedicada al comercio electrónico a través de la web **\*\*\*TIENDA.1** y dispone de gran cantidad de clientes, a la luz del número de afectados (...).

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD y 76.2 de la LOPDGDD, con respecto a la infracción cometida al vulnerar lo establecido en el artículo 32 del RGPD, permite fijar inicialmente una sanción de multa administrativa de 5.000,00 euros.

X

Obligación incumplida. Comunicación de una violación de la seguridad de los datos personales al interesado

La comunicación de una violación de la seguridad de los datos personales al interesado está regulada en el artículo 34 del RGPD, según el cual:

*"1. Cuando sea probable que la violación de la seguridad de los datos personales entrañe un alto riesgo para los derechos y libertades de las personas físicas, el responsable del tratamiento la comunicará al interesado sin dilación indebida.*

*2. La comunicación al interesado contemplada en el apartado 1 del presente artículo describirá en un lenguaje claro y sencillo la naturaleza de la violación de la seguridad de los datos personales y contendrá como mínimo la información y las medidas a que se refiere el artículo 33, apartado 3, letras b), c) y d).*

*3. La comunicación al interesado a que se refiere el apartado 1 no será necesaria si se cumple alguna de las condiciones siguientes:*

- a) el responsable del tratamiento ha adoptado medidas de protección técnicas y organizativas apropiadas y estas medidas se han aplicado a los datos personales afectados por la violación de la seguridad de los datos personales, en particular aquellas que hagan ininteligibles los datos personales para cualquier persona que no esté autorizada a acceder a ellos, como el cifrado;*
- b) el responsable del tratamiento ha tomado medidas ulteriores que garantizan que ya no exista la probabilidad de que se concrete el alto riesgo para los derechos y libertades del interesado a que se refiere el apartado 1;*
- c) suponga un esfuerzo desproporcionado. En este caso, se optará en su lugar por una comunicación pública o una medida semejante por la que se informe de manera igualmente efectiva a los interesados.*

*4. Cuando el responsable todavía no haya comunicado al interesado la violación de la seguridad de los datos personales, la autoridad de control, una vez considerada la probabilidad de que tal violación entrañe un alto riesgo, podrá exigirle que lo haga o podrá decidir que se cumple alguna de las condiciones mencionadas en el apartado 3."*

En el presente caso, el conocimiento de una violación de la seguridad de los datos personales se habría producido, según afirma la parte reclamante, por el traslado a HO de la reclamación por parte de esta Agencia. Dicho traslado se notificó el día 21/10/2023, a través del servicio de DEHÚ, accediendo HO a la notificación el día 31/10/2023. Sin embargo, la notificación a los interesados no se produce hasta el 19/12/2023, incumpliendo lo establecido por el artículo 34.1 del RGPD, que exige que dicha notificación se realice *"sin dilación indebida"*.



Por otro lado, se entiende que no se darían en este caso las circunstancias señaladas en artículo 34.3, dado que el conocimiento de la violación se ha producido más de un año después de producirse, habiendo quedado expuestos al menos desde enero de 2022, y los datos no estaban cifrados o protegidos de forma similar por otros medios técnicos.

Por tanto, de conformidad con las evidencias de las que se dispone en este momento de acuerdo de inicio de procedimiento sancionador, se considera que los hechos conocidos podrían ser constitutivos de una infracción, imputable a HO, por vulneración del artículo transcrito anteriormente.

## XI

### Tipificación de la infracción del artículo 34 del RGPD y calificación a efectos de prescripción

El artículo 83.4 del RGPD tipifica como infracción administrativa la vulneración de los artículos siguientes, se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10.000.000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

*"a) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43;"*

Por su parte, la LOPDGDD en su artículo 71, Infracciones, señala que:

*"Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica".*

A los solos efectos del plazo de prescripción, el artículo 74 de la LOPDGDD establece lo siguiente:

*"Se consideran leves y prescribirán al año las restantes infracciones de carácter meramente formal de los artículos mencionados en los apartados 4 y 5 del artículo 83 del Reglamento (UE) 2016/679 y, en particular, las siguientes:  
ñ) El incumplimiento del deber de comunicación al afectado de una violación de la seguridad de los datos que entrañe un alto riesgo para los derechos y libertades de los afectados, conforme a lo exigido por el artículo 34 del Reglamento (UE) 2016/679, salvo que resulte de aplicación lo previsto en el artículo 73 s) de esta ley orgánica."*

## XII

### Propuesta de sanción por vulneración del artículo 34 del RGPD

A fin de determinar la multa administrativa a imponer se han de observar las previsiones de los artículos 83.1 y 83.2 del RGPD, preceptos que señalan:

*“1. Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 9 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias.*

*2. Las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j). Al decidir la imposición de una multa administrativa y su cuantía en cada caso individual se tendrá debidamente en cuenta:*

- a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido;*
- b) la intencionalidad o negligencia en la infracción;*
- c) cualquier medida tomada por el responsable o encargado del tratamiento para paliar los daños y perjuicios sufridos por los interesados;*
- d) el grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32;*
- e) toda infracción anterior cometida por el responsable o el encargado del tratamiento;*
- f) el grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción;*
- g) las categorías de los datos de carácter personal afectados por la infracción;*
- h) la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida;*
- i) cuando las medidas indicadas en el artículo 58, apartado 2, hayan sido ordenadas previamente contra el responsable o el encargado de que se trate en relación con el mismo asunto, el cumplimiento de dichas medidas;*
- j) la adhesión a códigos de conducta en virtud del artículo 40 o a mecanismos de certificación aprobados con arreglo al artículo 42, y*
- k) cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción”.*

Por su parte, el artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD dispone:

*“1. Las sanciones previstas en los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679 se aplicarán teniendo en cuenta los criterios de graduación establecidos en el apartado 2 del citado artículo.*

*2. De acuerdo a lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta:*

- a) El carácter continuado de la infracción.*
- b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.*
- c) Los beneficios obtenidos como consecuencia de la comisión de la infracción.*

- d) La posibilidad de que la conducta del afectado hubiera podido inducir a la comisión de la infracción.*
- e) La existencia de un proceso de fusión por absorción posterior a la comisión de la infracción, que no puede imputarse a la entidad absorbente.*
- f) La afectación a los derechos de los menores.*
- g) Disponer, cuando no fuere obligatorio, de un delegado de protección de datos.*
- h) El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos, en aquellos supuestos en los que existan controversias entre aquellos y cualquier interesado”.*

En el presente caso, considerando la gravedad de la posible infracción, atendiendo especialmente a las consecuencias que su comisión provoca en los afectados, correspondería la imposición de multa, además de la adopción de medidas, si procede.

La multa que se imponga deberá ser, en cada caso individual, efectiva, proporcionada y disuasoria, conforme a lo establecido en el artículo 83.1 del RGPD. Para garantizar estos principios, se considera, con carácter previo, el volumen de negocio de HO, de (...)euros en el año 2023.

En este caso, la valoración inicial respecto a la infracción cometida al vulnerar lo establecido en el artículo 34 del RGPD, permite fijar inicialmente una sanción de multa administrativa de 1.000,00 euros.

### XIII

#### Obligación incumplida. Encargado del tratamiento

Las previsiones respecto al encargado del tratamiento están recogidas en el artículo 28 del RGPD, que estipula lo siguiente:

*"1. Cuando se vaya a realizar un tratamiento por cuenta de un responsable del tratamiento, este elegirá únicamente un encargado que ofrezca garantías suficientes para aplicar medidas técnicas y organizativas apropiadas, de manera que el tratamiento sea conforme con los requisitos del presente Reglamento y garantice la protección de los derechos del interesado.*

*(...)*

*3. El tratamiento por el encargado se registrará por un contrato u otro acto jurídico con arreglo al Derecho de la Unión o de los Estados miembros, que vincule al encargado respecto del responsable y establezca el objeto, la duración, la naturaleza y la finalidad del tratamiento, el tipo de datos personales y categorías de interesados, y las obligaciones y derechos del responsable. Dicho contrato o acto jurídico estipulará, en particular, que el encargado:*

*a) tratará los datos personales únicamente siguiendo instrucciones documentadas del responsable, inclusive con respecto a las transferencias de datos personales a un tercer país o una organización internacional, salvo que esté obligado a ello en virtud del Derecho de la Unión o de los Estados*

*miembros que se aplique al encargado; en tal caso, el encargado informará al responsable de esa exigencia legal previa al tratamiento, salvo que tal Derecho lo prohíba por razones importantes de interés público;*

*b) garantizará que las personas autorizadas para tratar datos personales se hayan comprometido a respetar la confidencialidad o estén sujetas a una obligación de confidencialidad de naturaleza legal;*

*c) tomará todas las medidas necesarias de conformidad con el artículo 32;*

*d) respetará las condiciones indicadas en los apartados 2 y 4 para recurrir a otro encargado del tratamiento;*

*e) asistirá al responsable, teniendo en cuenta la naturaleza del tratamiento, a través de medidas técnicas y organizativas apropiadas, siempre que sea posible, para que este pueda cumplir con su obligación de responder a las solicitudes que tengan por objeto el ejercicio de los derechos de los interesados establecidos en el capítulo III;*

*f) ayudará al responsable a garantizar el cumplimiento de las obligaciones establecidas en los artículos 32 a 36, teniendo en cuenta la naturaleza del tratamiento y la información a disposición del encargado;*

*g) a elección del responsable, suprimirá o devolverá todos los datos personales una vez finalice la prestación de los servicios de tratamiento, y suprimirá las copias existentes a menos que se requiera la conservación de los datos personales en virtud del Derecho de la Unión o de los Estados miembros;*

*h) pondrá a disposición del responsable toda la información necesaria para demostrar el cumplimiento de las obligaciones establecidas en el presente artículo, así como para permitir y contribuir a la realización de auditorías, incluidas inspecciones, por parte del responsable o de otro auditor autorizado por dicho responsable.*

*En relación con lo dispuesto en la letra h) del párrafo primero, el encargado informará inmediatamente al responsable si, en su opinión, una instrucción infringe el presente Reglamento u otras disposiciones en materia de protección de datos de la Unión o de los Estados miembros.*

(...)

*9. El contrato u otro acto jurídico a que se refieren los apartados 3 y 4 constará por escrito, inclusive en formato electrónico.*

En el presente caso, en su respuesta al requerimiento en la Actuación previa de investigación, de 24/04/2024, HO señala lo siguiente con respecto a este punto:

*“En el caso de la compañía que realiza el mantenimiento de la página web, esta empresa, comenzó con un proyecto en DICIEMBRE 2021, que fue cuando se firmó el primer contrato, hasta la ACTUALIDAD. **\*\*\*CONSULTORA.1**, ha estado trabajando y ayudándonos en tratar de cumplir con todo lo que conlleva nuestra página web. No tratan datos de clientes en su trabajo en la página web. Por esto, no han sido considerados como encargados de tratamiento, ni como subencargados.”*

Sin embargo, de acuerdo con lo manifestado por HO en relación con su hipótesis sobre el motivo por el que pudo producirse la brecha, la empresa **\*\*\*CONSULTORA.1**, para la migración de la página web, recibe un fichero con datos personales de los

clientes de la empresa con el objetivo de trasladarlos a la nueva web. En este sentido realiza un tratamiento de datos de acuerdo con los criterios del artículo 4.2 del RGPD, que lo define del siguiente modo:

*2) «tratamiento»: cualquier operación o conjunto de operaciones realizadas sobre datos personales o conjuntos de datos personales, ya sea por procedimientos automatizados o no, como la recogida, registro, organización, estructuración, conservación, adaptación o modificación, extracción, consulta, utilización, comunicación por transmisión, difusión o cualquier otra forma de habilitación de acceso, cotejo o interconexión, limitación, supresión o destrucción*

Dicho tratamiento lo hace por cuenta del responsable, HO, por lo que puede ser considerado encargado, de acuerdo con el artículo 4.8 del RGPD, que lo define del siguiente modo:

*8) «encargado del tratamiento» o «encargado»: la persona física o jurídica, autoridad pública, servicio u otro organismo que trate datos personales por cuenta del responsable del tratamiento*

Por tanto, de conformidad con las evidencias de las que se dispone en este momento de acuerdo de inicio de procedimiento sancionador, se considera que los hechos conocidos podrían ser constitutivos de una infracción, imputable a HO, por vulneración del artículo transcrito anteriormente, en la medida en que no existía un contrato para regir dicho tratamiento.

#### XIV

#### Tipificación de la infracción del artículo 28 del RGPD y calificación a efectos de prescripción

El artículo 83.4 del RGPD tipifica como infracción administrativa la vulneración de los artículos siguientes, se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10.000.000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

- "a) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43;*
- b) las obligaciones de los organismos de certificación a tenor de los artículos 42 y 43;*
- c) las obligaciones de la autoridad de control a tenor del artículo 41, apartado 4."*

Por su parte, la LOPDGDD en su artículo 71, Infracciones, señala que:

*"Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica".*



A los solos efectos del plazo de prescripción, el artículo 73 de la LOPDGDD establece lo siguiente:

*"En función de lo que establece el artículo 83.4 del Reglamento (UE) 2016/679 se consideran graves y prescribirán a los dos años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:*

*k) Encargar el tratamiento de datos a un tercero sin la previa formalización de un contrato u otro acto jurídico escrito con el contenido exigido por el artículo 28.3 del Reglamento (UE) 2016/679."*

## XV

### Propuesta de sanción por vulneración del artículo 28 del RGPD

A fin de determinar la multa administrativa a imponer se han de observar las previsiones de los artículos 83.1 y 83.2 del RGPD, preceptos que señalan:

*"1. Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 9 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias.*

*2. Las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j). Al decidir la imposición de una multa administrativa y su cuantía en cada caso individual se tendrá debidamente en cuenta:*

*a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido;*

*b) la intencionalidad o negligencia en la infracción;*

*c) cualquier medida tomada por el responsable o encargado del tratamiento para paliar los daños y perjuicios sufridos por los interesados;*

*d) el grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32;*

*e) toda infracción anterior cometida por el responsable o el encargado del tratamiento;*

*f) el grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción;*

*g) las categorías de los datos de carácter personal afectados por la infracción;*

*h) la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida;*

*i) cuando las medidas indicadas en el artículo 58, apartado 2, hayan sido ordenadas previamente contra el responsable o el encargado de que se trate en relación con el mismo asunto, el cumplimiento de dichas medidas;*

*j) la adhesión a códigos de conducta en virtud del artículo 40 o a mecanismos de certificación aprobados con arreglo al artículo 42, y*



*k) cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción”.*

Por su parte, el artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD dispone:

*“1. Las sanciones previstas en los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679 se aplicarán teniendo en cuenta los criterios de graduación establecidos en el apartado 2 del citado artículo.*

*2. De acuerdo a lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta:*

- a) El carácter continuado de la infracción.*
- b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.*
- c) Los beneficios obtenidos como consecuencia de la comisión de la infracción.*
- d) La posibilidad de que la conducta del afectado hubiera podido inducir a la comisión de la infracción.*
- e) La existencia de un proceso de fusión por absorción posterior a la comisión de la infracción, que no puede imputarse a la entidad absorbente.*
- f) La afectación a los derechos de los menores.*
- g) Disponer, cuando no fuere obligatorio, de un delegado de protección de datos.*
- h) El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos, en aquellos supuestos en los que existan controversias entre aquellos y cualquier interesado”.*

En el presente caso, considerando la gravedad de la posible infracción, atendiendo especialmente a las consecuencias que su comisión provoca en los afectados, correspondería la imposición de multa, además de la adopción de medidas, si procede.

La multa que se imponga deberá ser, en cada caso individual, efectiva, proporcionada y disuasoria, conforme a lo establecido en el artículo 83.1 del RGPD. Para garantizar estos principios, se considera, con carácter previo, el volumen de negocio de HO, de (...) euros en el año 2023.

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, de conformidad con las evidencias de que se dispone en el presente momento de acuerdo de inicio de procedimiento sancionador, y sin perjuicio de lo que resulte de la instrucción, se considera que procede graduar la sanción a imponer de acuerdo con las circunstancias siguientes, contempladas en los preceptos antes citados.

Con carácter previo, se estima que concurren las circunstancias siguientes:

La naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el

número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido (artículo 83.2, letra a), del RGPD).

En primer lugar, cabe tomar en consideración en relación con la gravedad de la infracción, que la ausencia de un contrato con el encargado del tratamiento, en los términos en que lo establece el artículo 28 del RGPD, redundaría en una ausencia de instrucciones por parte de HO como responsable del mismo.

Asimismo, se considera como factor de graduación en calidad de agravante la vinculación de la actividad del infractor con la realización de tratamientos de datos personales (artículo 76.2, letra b), de la LOPDGDD). El responsable del tratamiento es una empresa dedicada al comercio electrónico a través de la web **\*\*\*TIENDA.1** y dispone de gran cantidad de clientes, a la luz del número de afectados (...)

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD y 76.2 de la LOPDGDD, con respecto a la infracción cometida al vulnerar lo establecido en el artículo 28 del RGPD, permite fijar inicialmente una sanción de multa administrativa de 5.000,00 euros.

## XVI

### Medidas correctivas

De confirmarse la infracción, la resolución que se dicte podrá establecer las medidas correctivas que la entidad infractora deberá adoptar para poner fin al incumplimiento de la legislación de protección de datos personales, en este caso de los artículos 5.1 f), 32, 33, 34 y 28 del RGPD, de acuerdo con lo establecido en el citado artículo 58.2.d) del RGPD, según el cual cada autoridad de control podrá *“ordenar al responsable o encargado del tratamiento que las operaciones de tratamiento se ajusten a las disposiciones del presente Reglamento, cuando proceda, de una determinada manera y dentro de un plazo especificado...”*

Así, se podrá requerir a la entidad responsable para que adecúe su actuación a la normativa de protección de datos personales, con el alcance expresado en los anteriores Fundamentos de Derecho.

En el presente acto se establece cuál es la presunta infracción cometida y los hechos que podrían dar lugar a esa posible vulneración de la normativa de protección de datos, de lo que se infiere con claridad cuáles son las medidas a adoptar, sin perjuicio de que el tipo de procedimientos, mecanismos o instrumentos concretos para implementarlas corresponda a la parte sancionada, pues es el responsable del tratamiento quien conoce plenamente su organización y ha de decidir, en base a la responsabilidad proactiva y en enfoque de riesgos, cómo cumplir con el RGPD y la LOPDGDD.

En este caso, con independencia de lo anterior, de conformidad con las evidencias de que se dispone en el presente momento de acuerdo de inicio de procedimiento sancionador, en la resolución que se adopte se podrá requerir a HO para que, en el plazo de tres meses, a contar desde la fecha de ejecutividad de la resolución finalizadora de este procedimiento, adopte las medidas siguientes:

- Acreditar la adopción de las medidas necesarias para garantizar el cumplimiento de lo dispuesto en el artículo 5.1 f) del RGPD, de tal manera que garantice una seguridad adecuada en el tratamiento de los datos personales, a través de medios adecuados, como la utilización de técnicas de encriptación para el almacenamiento de datos.
- Acreditar la adopción de las medidas necesarias para garantizar el cumplimiento de lo dispuesto en el artículo 32 del RGPD, de tal manera que se garantice un nivel de seguridad adecuado al riesgo, a través de medios adecuados, como la utilización de técnicas de hash o encriptación para el almacenamiento de datos, así como la realización de pruebas de seguridad.
- Acreditar la realización del correspondiente contrato de encargado de tratamiento con **\*\*\*CONSULTORA.1** o la empresa que realice en ese momento tareas que impliquen operaciones de tratamiento de datos personales, como fueron, en su momento, las de migración de la página web.

La imposición de estas medidas es compatible con la sanción consistente en multa administrativa, según lo dispuesto en el art. 83.2 del RGPD.

Se advierte que no atender la posible orden de adopción de medidas impuestas por este organismo en la resolución del presente procedimiento sancionador podrá ser considerado como una infracción administrativa conforme a lo dispuesto en el RGPD, tipificada como infracción en su artículo 83.5 y 83.6, pudiendo motivar tal conducta la apertura de un ulterior procedimiento administrativo sancionador.

Asimismo, se recuerda que ni el reconocimiento de la infracción cometida ni, en su caso, el pago voluntario de las cuantías propuestas, eximen de la obligación de adoptar las medidas pertinentes para que cese la conducta o se corrijan los efectos de la infracción cometida y la de acreditar ante esta AEPD el cumplimiento de esa obligación.

Por lo tanto, a tenor de lo anteriormente expuesto, por la Directora de la Agencia Española de Protección de Datos,

SE ACUERDA:

**PRIMERO:** INICIAR PROCEDIMIENTO SANCIONADOR a **DISEÑOS HERMANAS ORTIZ CAÑÓN, S.L.**, con NIF **B39843487**, por la presunta infracción de los siguientes artículos del RGPD:

- Artículo 5.1 f), tipificada en el artículo 83.5
- Artículo 32, tipificada en el artículo 83.4
- Artículo 34, tipificada en el artículo 83.4
- Artículo 28, tipificada en el artículo 83.4

**SEGUNDO:** NOMBRAR como instructor a **D.D.D.** y, como secretaria, a **E.E.E.**, indicando que podrán ser recusados, en su caso, conforme a lo establecido en los

artículos 23 y 24 de la Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público (LRJSP).

**TERCERO:** INCORPORAR al expediente, a efectos probatorios, la reclamación interpuesta por la parte reclamante y su documentación, así como, así como los documentos obtenidos y generados por la Subdirección General de Inspección de Datos en las actuaciones previas al inicio del presente procedimiento sancionador.

**CUARTO:** QUE a los efectos previstos en el art. 64.2 b) de la ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas, la sanción que pudiera corresponder sería de multa administrativa de **TREINTA Y UN MIL EUROS (31.000,00 euros)**, sin perjuicio de lo que resulte de la instrucción, correspondiente a las siguientes infracciones:

- Artículo 5.1 f), multa administrativa de VEINTE MIL EUROS (20.000,00 euros)
- Artículo 32, multa administrativa de CINCO MIL EUROS (5.000,00 euros)
- Artículo 34, multa administrativa de MIL EUROS (1.000,00 euros)
- Artículo 28, multa administrativa de CINCO MIL EUROS (5.000,00 euros)

**QUINTO:** NOTIFICAR el presente acuerdo a **DISEÑOS HERMANAS ORTIZ CAÑÓN, S.L.**, con NIF **B39843487**, otorgándole un plazo de audiencia de diez días hábiles para que formule las alegaciones y presente las pruebas que considere convenientes. En su escrito de alegaciones deberá facilitar su NIF y el número de procedimiento que figura en el encabezamiento de este documento.

De conformidad con lo dispuesto en el artículo 85 de la LPACAP, podrá reconocer su responsabilidad dentro del plazo otorgado para la formulación de alegaciones al presente acuerdo de inicio; lo que llevará aparejada una reducción de un 20% de la sanción que proceda imponer en el presente procedimiento. Con la aplicación de esta reducción, la sanción quedaría establecida en **24.800,00 euros**, resolviéndose el procedimiento con la imposición de esta sanción.

Del mismo modo podrá, en cualquier momento anterior a la resolución del presente procedimiento, llevar a cabo el pago voluntario de la sanción propuesta, lo que supondrá la reducción de un 20% de su importe. Con la aplicación de esta reducción, la sanción quedaría establecida en **24.800,00 euros** y su pago implicará la terminación del procedimiento, sin perjuicio de la imposición de las medidas correspondientes.

La reducción por el pago voluntario de la sanción es acumulable a la que corresponde aplicar por el reconocimiento de la responsabilidad, siempre que este reconocimiento de la responsabilidad se ponga de manifiesto dentro del plazo concedido para formular alegaciones a la apertura del procedimiento. El pago voluntario de la cantidad referida en el párrafo anterior podrá hacerse en cualquier momento anterior a la resolución. En este caso, si procediera aplicar ambas reducciones, el importe de la sanción quedaría establecido en **18.600,00 euros**.

En todo caso, la efectividad de cualquiera de las dos reducciones mencionadas estará condicionada al desistimiento o renuncia expresos de cualquier acción o recurso en vía administrativa contra la sanción.

A estos efectos, en caso de acogerse a alguna de ellas, deberá remitir a la Subdirección General de Inspección de datos comunicación expresa del desistimiento o renuncia a cualquier acción o recurso en vía administrativa contra la sanción indicando a cuál de las dos reducciones se acoge o si es a las dos.

En caso de que optara por proceder al pago voluntario de cualquiera de las cantidades señaladas anteriormente (**24.800,00 euros** o **18.600,00 euros**), deberá hacerlo efectivo mediante su ingreso en la cuenta nº **IBAN: ES00-0000-0000-0000-0000-0000 (BIC/Código SWIFT: CAIXESBBXXX)** abierta a nombre de la Agencia Española de Protección de Datos en la entidad bancaria CAIXABANK, S.A., indicando en el concepto el número de referencia del procedimiento que figura en el encabezamiento de este documento y la causa de reducción del importe a la que se acoge.

Asimismo, deberá enviar el justificante del ingreso a la Subdirección General de Inspección junto con la comunicación expresa del desistimiento o renuncia a cualquier acción o recurso en vía administrativa contra la sanción para continuar con el procedimiento en concordancia con la cantidad ingresada.

Por último, se señala que conforme a lo establecido en el artículo 112.1 de la LPACAP, contra el presente acto no cabe recurso administrativo alguno.

1479-141024

Mar España Martí  
Directora de la Agencia Española de Protección de Datos

&gt;&gt;

**SEGUNDO:** En fecha 28 de noviembre de 2024, **HO** ha procedido al pago de la sanción en la cuantía de **18.600,00 euros** haciendo uso de las dos reducciones previstas en el acuerdo de inicio transcrito anteriormente, lo que implica el reconocimiento de la responsabilidad en relación con los hechos a los que se refiere el acuerdo de inicio y su calificación jurídica.

**TERCERO:** **HO** ha renunciado expresamente a cualquier acción o recurso en vía administrativa contra la sanción.

**CUARTO:** En el acuerdo de inicio transcrito anteriormente se señalaba que, de confirmarse la infracción, podría acordarse imponer al responsable la adopción de medidas adecuadas para ajustar su actuación a la normativa mencionada en este acto, de acuerdo con lo establecido en el citado artículo 58.2 d) del RGPD, según el cual cada autoridad de control podrá “ordenar al responsable o encargado del tratamiento que las operaciones de tratamiento se ajusten a las disposiciones del

presente Reglamento, cuando proceda, de una determinada manera y dentro de un plazo especificado...”.

Habiéndose reconocido la responsabilidad de la infracción, procede la imposición de las medidas incluidas en el acuerdo de inicio.

## FUNDAMENTOS DE DERECHO

### I

#### Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), es competente para resolver este procedimiento la Presidencia de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *"Los procedimientos tramitados por la Agencia Española de Protección de Datos se registrarán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos."*

### II

#### Terminación del procedimiento

El artículo 85 de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en lo sucesivo, LPACAP), bajo la rúbrica *"Terminación en los procedimientos sancionadores"* dispone lo siguiente:

*"1. Iniciado un procedimiento sancionador, si el infractor reconoce su responsabilidad, se podrá resolver el procedimiento con la imposición de la sanción que proceda.*

*2. Cuando la sanción tenga únicamente carácter pecuniario o bien quepa imponer una sanción pecuniaria y otra de carácter no pecuniario pero se ha justificado la improcedencia de la segunda, el pago voluntario por el presunto responsable, en cualquier momento anterior a la resolución, implicará la terminación del procedimiento, salvo en lo relativo a la reposición de la situación alterada o a la determinación de la indemnización por los daños y perjuicios causados por la comisión de la infracción.*

*3. En ambos casos, cuando la sanción tenga únicamente carácter pecuniario, el órgano competente para resolver el procedimiento aplicará reducciones de, al menos, el 20 % sobre el importe de la sanción propuesta, siendo éstos acumulables entre sí. Las citadas reducciones, deberán estar determinadas en la notificación de iniciación del procedimiento y su efectividad estará condicionada al desistimiento o renuncia de cualquier acción o recurso en vía administrativa contra la sanción.*



*El porcentaje de reducción previsto en este apartado podrá ser incrementado reglamentariamente.”*

### III

#### Pago voluntario y reconocimiento de responsabilidad

De conformidad con lo dispuesto en el citado artículo 85 de la LPACAP, en el acuerdo de inicio notificado se informaba sobre la posibilidad de reconocer la responsabilidad y de realizar el pago voluntario de la sanción propuesta, lo que supondría dos reducciones acumulables de un 20% cada una. Con la aplicación de estas dos reducciones, la sanción quedaría establecida en **18.600,00 euros** y su pago implicaría la terminación del procedimiento, sin perjuicio de la imposición de las medidas correspondientes.

Tras la notificación del citado acuerdo de inicio, **HO** ha procedido al reconocimiento de la responsabilidad y al pago voluntario de la sanción, acogándose a las dos reducciones previstas y renunciando expresamente a cualquier acción o recurso en vía administrativa.

Debe tenerse en cuenta que, de acuerdo con los preceptos de la LPACAP, así como de la jurisprudencia del Tribunal Supremo en esta materia, el ejercicio del pago voluntario por el presunto responsable no exime a la administración de la obligación de resolver y notificar todos los procedimientos, cualquiera que sea su forma de iniciación. De igual forma, el artículo 88 de la citada norma establece que la resolución que ponga fin al procedimiento decidirá todas las cuestiones planteadas por los interesados y aquellas otras derivadas del mismo.

Por lo tanto, de acuerdo con la legislación aplicable y valorados los criterios de graduación de las sanciones cuya existencia ha quedado acreditada, la Presidencia de la Agencia Española de Protección de Datos RESUELVE:

PRIMERO: DECLARAR la comisión de las infracciones y CONFIRMAR las sanciones determinadas en la parte dispositiva del acuerdo de inicio transcrito en la presente resolución.

La suma de las citadas cuantías arroja una cantidad total **31.000,00 euros**.

Tras haber procedido **DISEÑOS HERMANAS ORTIZ CAÑÓN, S.L.** al pronto pago y reconocimiento de responsabilidad, se procede, en virtud del artículo 85 de la LPACAP, a la reducción de un 40% del total mencionado, lo cual supone la cantidad definitiva de **18.600,00 euros**.

SEGUNDO: DECLARAR la terminación del procedimiento **EXP202315109**, de conformidad con lo establecido en el artículo 85 de la LPACAP.

TERCERO: ORDENAR a **DISEÑOS HERMANAS ORTIZ CAÑÓN, S.L.** para que en el plazo de 3 meses desde que la presente resolución sea firme y ejecutiva, notifique a la Agencia la adopción de las medidas que se describen en los fundamentos de derecho del acuerdo de inicio transcrito en la presente resolución.

**CUARTO:** NOTIFICAR la presente resolución a **DISEÑOS HERMANAS ORTIZ CAÑÓN, S.L.**.

**QUINTO:** De acuerdo con lo previsto en el artículo 85 de la LPACAP que condiciona la reducción por pago voluntario y reconocimiento de la responsabilidad al desistimiento o renuncia de cualquier acción o recurso en vía administrativa, por parte de la presente autoridad se acepta la renuncia expresamente manifestada por **DISEÑOS HERMANAS ORTIZ CAÑÓN, S.L.**, no cabiendo en consecuencia la interposición de recurso potestativo de reposición frente a la presente resolución, todo ello sin perjuicio de la posibilidad de acudir a la vía jurisdiccional contencioso-administrativa.

En consecuencia, teniendo en cuenta lo dispuesto en el artículo 90 de la LPACAP, dado que no cabe ningún recurso en vía administrativa al haber renunciado expresamente, la presente resolución será firme y plenamente ejecutiva a partir de su notificación.

No obstante, conforme a lo previsto en el artículo 90.3.a) de la LPACAP, se podrá suspender cautelarmente la resolución firme en vía administrativa si el interesado manifiesta su intención de interponer recurso contencioso-administrativo. De ser éste el caso, el interesado deberá comunicar formalmente este hecho mediante escrito dirigido a la Agencia Española de Protección de Datos, presentándolo a través del Registro Electrónico de la Agencia [<https://sedeagpd.gob.es/sede-electronica-web/>], o a través de alguno de los restantes registros previstos en el art. 16.4 de la citada Ley 39/2015, de 1 de octubre. También deberá trasladar a la Agencia la documentación que acredite la interposición efectiva del recurso contencioso-administrativo. Si la Agencia no tuviese conocimiento de la interposición del recurso contencioso-administrativo en el plazo de dos meses desde el día siguiente a la notificación de la presente resolución, daría por finalizada la suspensión cautelar.

De conformidad con lo establecido en el artículo 50 de la LOPDGDD, la presente Resolución se hará pública una vez haya sido notificada a los interesados.

1259-180225

Olga Pérez Sanjuán

La Subdirectora General de Inspección de Datos, de conformidad con el art. 48.2 LOPDGDD, por vacancia del cargo de Presidencia y Adjuntía